



IN RE: PLDT INC.

NPC BN 18-206

X-----X

ORDER

Before the Commission is the Compliance of the PLDT, Inc. (PLDT) dated 25 June 2021 with the Order dated 10 May 2021 of the National Privacy Commission (Commission), through its Complaints and Investigation Division (CID).

On 21 September 2018, the Data Protection Officer of PLDT received a report that “lab test results forms of 2 employees from SMART Communication Inc. were used as scratch papers as covering transmittal letters/memos used within the PLDT Group”.¹ PLDT stated that the incident was caused by one of the employees of its third-party partner for its medical services.²

Further, PLDT alleged that it did all possible actions to ensure that the subject personal data in the incident would no longer be shared within their organization, considering that it happened in one of its companies.³

In addition, PLDT stated in its initial report to the Commission that it reported the incident due to the “sensitive nature of the personal information which might have been compromised (i.e., medical laboratory test results).”⁴

PLDT also stated that it instructed its third-party medical service provider to execute appropriate sanctions for the responsible

¹ PLDT Inc., initial notification report “Data Breach Notification-Exposed Medical Records” dated 30 October 2018 p.1

² *Id.*

³ *Id.*

⁴ *Id.*

employee.⁵ Further, refresher training programs for its Clinic Staff regarding “Privacy Do’s and Don’ts were conducted as a reminder of the “strict prohibition against the use of medical records as scratch papers”.⁶

Lastly, PLDT requested to suspend data subject notification, claiming that it was “able to contain the processing of the sensitive personal information of the 2 [two] affected data subjects.”⁷

On 10 May 2021 the Commission through its CID, issued an Order directing PLDT to submit a Post-Breach Report, which should include:

- A. Description of the personal data breach, its root cause and circumstances regarding its discovery;
- B. Actions and decisions of the incident response team;
- C. Outcome of the breach management, and difficulties encountered; and
- D. Compliance with notification requirements and assistance provided to affected data subjects.⁸

On 25 June 2021, PLDT submitted its Compliance to the Order dated 10 May 2021.⁹

In its Compliance, PLDT reiterated that the incident transpired when the “dorsal side of the printed sheets of paper containing lab results of two (2) Smart employees were used to print transmittal slips by a personal information processor of PLDT’s Medical Clinic”.¹⁰

Further, PLDT admitted that the incident involved sensitive personal information and the consequence of the same, wherein:

The data breach involved sensitive personal information such as dates of birth, and other information such as their respective patient identification numbers (PIN), age, sex, and complete name. Also included in the printouts were the names of the

⁵ PLDT Inc., initial notification report “Data Breach Notification-Exposed Medical Records” dated 30 October 2018 p.1

⁶ *Id.* at p.2

⁷ *Id.*

⁸ Order dated 10 May 2021, National Privacy Commission

⁹ PLDT Inc. Letter (Order dated 10 May 2021 re NPC BN No. 18-206) dated 25 June 2021

¹⁰ *Id.*, Annex A p. 1

respective hospitals that conducted the lab tests. Given that the PIN is indicated, there is a possibility that an unauthorized person who gains access to the information would be able to have unauthorized access as well to the patient records of the data subjects.¹¹

In addition, PLDT specifically stated that the sensitive personal information involved in the incident includes date of birth and age, marital status, information about an individual's health, and patient identification number.¹²

Moreover, to address the breach incident, PLDT manifested that it advised the third-party medical services provider to take appropriate actions, reminded its medical staff not to reuse printouts as scratch papers that contain personal information, and required its medical services provider to ensure that its employees assigned to PLDT receives proper training of privacy and information security.¹³ It also claimed that printed sheets bearing the Smart employees' personal information were securely destroyed.¹⁴

Finally, PLDT stated that it did not receive a response from the Commission with regard to its request for suspension of data subject notification, apart from the Order dated 10 May 2021.¹⁵

In view thereof, the Commission finds that PLDT must notify the affected data subjects and submit proof of notification.

Section 11, NPC Circular No. 16-03 (Personal Data Breach Management) provides when notification shall be required, to wit:

SECTION 11. *When notification is required.*

Notification shall be required upon knowledge of or when there is reasonable belief by the personal information controller or personal information processor that a personal data breach requiring notification has occurred, under the following conditions:

¹¹ *Id.*

¹² *Id.*, Annex A p. 2

¹³ PLDT Inc. Letter (Order dated 10 May 2021 re NPC BN No. 18-206) dated 25 June 2021, Annex A p. 3

¹⁴ *Id.*

¹⁵ *Id.*

A. The personal data involves sensitive personal information or any other information that may be used to enable identity fraud. For this purpose, “other information” shall include, but not be limited to: data about the financial or economic situation of the data subject; usernames, passwords and other login data; biometric data; copies of identification documents, licenses or unique identifiers like Philhealth, SSS, GSIS, TIN number; or other similar information, which may be made the basis of decisions concerning the data subject, including the grant of rights or benefits.

B. There is reason to believe that the information may have been acquired by an unauthorized person; and

C. The personal information controller or the Commission believes that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject.¹⁶

In this case, all the elements of mandatory breach notification are present. As to the first element, the lab test results of the affected data subjects contain sensitive personal information such as age, marital status, and information about an individual’s health.

Section 3 (1) of Republic Act 10173 or the Data Privacy Act of 2012 (DPA) defines sensitive personal information as personal information:

(1) About an individual’s race, ethnic origin, **marital status, age**, color, and religious, philosophical or political affiliations;

(2) About an **individual’s health**, education, genetic or sexual life of a person, or to any proceeding for any offense committed or alleged to have been committed by such person, the disposal of such proceedings, or the sentence of any court in such proceedings;

(3) Issued by government agencies peculiar to an individual which includes, but not limited to, social security numbers, previous or current health records, licenses or its denials, suspension or revocation, and tax returns; and

¹⁶ National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, rule V, § 11 (15 December 2016) (NPC Circular 16-03).

(4) Specifically established by an executive order or an act of Congress to be kept classified.¹⁷ (emphasis supplied)

From the above definition, it is apparent that the first element of mandatory data subject notification is present.

With regard to the second element, PLDT stated that the printed sheet of the lab test results of its two (2) employees were used as scratch paper for its transmittal letters.¹⁸ To recall, PLDT stated in its Compliance that “The Personal data breach was discovered by the recipient entity, which is also a member of the PLDT Group”.¹⁹

Indubitably, the second element of mandatory data subject notification is apparent in this incident since the lab test results were used as scratch papers for the transmittal letters and received by an unauthorized employee. Hence, there is reason to believe that the information may have been acquired by an unauthorized person,²⁰

Moreover, despite that the incident occurred among the employees of PLDT, the fact that the lab test results were acquired by an unauthorized employee to receive or access the scratch papers that contained the personal data of the affected data subjects sufficiently satisfied the second element.

The third element is also apparent considering that the lab test results personal data involved in the incident. To recall, PLDT admitted that “there is a possibility that an unauthorized person who gains access to the information would be able to have unauthorized access as well to the patient records of the data subjects”.²¹

¹⁷ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter I, § 3 (I) (2012).

¹⁸ PLDT Inc. Letter (Order dated 10 May 2021 re NPC BN No. 18-206) dated 25 June 2021, *Annex A*

¹⁹ *Id. at p. 3*

²⁰ National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, Rule I, § 3, L (15 December 2016) (NPC Circular 16-03).

²¹ PLDT Inc. Letter (Order dated 10 May 2021 re NPC BN No. 18-206) dated 25 June 2021, *Annex A p. 1*

On this note, it must be emphasized that PLDT believes that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject, in line with its admission. Furthermore, the incident involves sensitive personal information and other information that, under the circumstances, may be used to enable identity fraud.”²²

In this regard, the unauthorized acquisition is likely to give rise to a real risk of serious harm to the affected data subjects, contrary to the CID’s findings that the matter does not fall under mandatory breach notification in its Final Breach Notification Evaluation Report on the basis that “since the transmittal slips were only used within the PLDT Group, it may have been accessed by PLDT personnel only”,²³

The third element of mandatory data subject notification does not distinguish whether the unauthorized acquisition is within the internal environment of a personal information controller. It simply states that “the unauthorized acquisition is likely to give rise to a real risk of serious harm”²⁴, hence, the CID is wrong in concluding that the third requisite does not exist based on the sole reason that the breach occurred within the organization.

Lastly, as to PLDT’s request for suspension of data subject notification, postponement of data subject notification will only be allowed in exceptional circumstances following NPC Circular No. 16-03, Section 18 B, which provides the guidelines for postponement of notification, thus:

B. Exemption or Postponement of Notification.

If it is not reasonably possible to notify the data subjects within the prescribed period, the personal information controller shall request the Commission for an exemption from the notification requirement, or the postponement of the notification.

A personal information controller may be exempted from the notification requirement where the Commission determines that

²² An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter V, § 20 (f) (2012)

²³ Final Breach Notification Evaluation Report dated 29 April 2024, NPC BN No. 18-206 In re: PLDT, Inc.

²⁴ National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, rule V, § 11 (15 December 2016) (NPC Circular 16-03).

such notification would not be in the public interest or in the interest of the affected data subjects.

The Commission may authorize the postponement of notification where it may hinder the progress of a criminal investigation related to a serious breach, taking into account circumstances provided in Section 13 of this Circular, and other risks posed by the personal data breach.²⁵ (emphasis supplied)

Accordingly, nothing in the submission of PLDT states that data subject notification may hinder the progress of a criminal investigation. Hence, the request for postponement of the data subjects' notification is not warranted.

WHEREFORE, premises considered, the Commission resolves to:

- 1) **ORDER** PLDT, Inc., to **notify all affected data subjects** and **submit proof of notification** directly to the Compliance and Monitoring Division (CMD) within fifteen (15) days from receipt of this Order; and
- 2) **DIRECT** the CMD to issue the appropriate orders necessary to evaluate and monitor the completeness of PLDT Inc.'s data breach notification and assess its breach management pursuant to NPC Circular 16-03 (Personal Data Breach Management).

SO ORDERED.

City of Pasay, Philippines.

16 May 2024.

SGD
JOHN HENRY D. NAGA
Privacy Commissioner

²⁵ National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, Rule V, § 18, B (15 December 2016) (NPC Circular 16-03).

WE CONCUR:

SGD
LEANDRO ANGELO Y. AGUIRRE
Deputy Privacy Commissioner

SGD
NERISSA N. DE JESUS
Deputy Privacy Commissioner

Copy furnished:

JAG
Data Privacy Officer
SMART COMMUNICATIONS INC.

LBJ
Group Data Privacy Officer
PLDT GROUP

COMPLIANCE AND MONITORING DIVISION
COMPLAINTS AND INVESTIGATION DIVISION
ENFORCEMENT DIVISION
GENERAL RECORDS UNIT
National Privacy Commission